

CONCLUDING ANALYSIS

Security Incident Report — Post-Incident Review

Ubisoft & Discord.io Data Breach

Group 2: Daniel Lindo, Emmanuel Ajayi, Melvin Viado, Tim Loudon

MGMT 1212: Incident Response and Handling

Cybersecurity, Durham College

April 22, 2026

Ubisoft Data Breach

1. Linking Post-Incident Findings Back to the Preparation Phase

The July 2013 Ubisoft Uplay breach offers a great lesson in particular because it was more than just a one-time incident. At the point when hackers broke into the Uplay customer database and stole data of about 58 million users, Ubisoft had already two other major security issues that year: one was a bug of the Uplay browser plugin that Google security researcher Travis Ormandy identified as behaving very similarly to a rootkit; the second was a DRM loophole making it possible to download illegally unreleased software. Three incidents over twelve months from the same platform is a problem of the whole system, not a matter of mere chance. The AAR has to handle it as a matter of fact.

1.1 Recurring Vulnerabilities Were Not Addressed Holistically

Every one of the three incidents in 2013 ought to have been a signal for a thorough security assessment of the whole Uplay platform. The facts point in the direction that it was never done in a significant manner. The AAR has to figure out if a deep examination was done after the first two incidents and, if it was, why the weakness used in the July attack wasn't found. In the future, a security breach hitting a vital platform should lead to a scrutiny of related systems - not only the part that was directly breached - as a matter of course.

1.2 The Specific Attack Vector Remains Undisclosed

Ubisoft revealed in a post that "one of its websites was exploited" to gain access. They did not disclose what the vulnerability was. Internally, the SIR and AAR have to clearly identify the root cause - the exact vulnerability class, the affected component, and the method of exploitation. Ambiguous descriptions won't satisfy anyone: neither regulators, nor lawyers, nor engineers who will work to assure this won't be repeated.

1.3 Password Storage Standards Were Never Clarified

Ubisoft confirmed that stolen passwords were encrypted but refused to specify how. That deliberate vagueness strongly suggests the implementation did not meet the standards of the time. Whether MD5, SHA-1, or something weaker was used matters enormously for assessing real-world risk to users. The AAR must establish the exact hashing algorithm and mandate a migration to a modern, slow-hashing standard such as bcrypt or Argon2 if one was not already in use.

1.4 Mandatory Account Creation Created Compulsory Data Exposure

Uplay was not optional. Millions of users were required to register simply to play games they had already purchased, meaning they had no meaningful choice about whether to accept the data protection risk. That context heightens the organization's duty of care significantly. The AAR should flag mandatory data collection as a policy issue and examine whether the security investment matched the obligation that came with it.

1.5 Detection Timeline Was Not Transparent

How long the attackers had access before the breach was detected was never disclosed publicly. That gap in the record must be closed in the internal investigation. Detection speed directly determines the scope of harm, and the AAR must establish the actual timeline and use it to evaluate whether monitoring tools were adequate.

2. Recommended Controls and Training

2.1 Technical Controls

Control	Rationale	Priority
Third-Party Penetration Testing (bi-annual)	Three incidents in one year demand independent testing, not just internal reviews.	Critical
Strong Password Hashing (bcrypt / Argon2)	The undisclosed encryption method must be replaced with a documented, audited, slow-hashing algorithm with per-user salts.	Critical
Web Application Firewall (WAF)	Blocks common web exploit patterns even when vulnerable code reaches production.	Critical
Database Activity Monitoring (DAM)	Detects bulk data access or anomalous queries in real time, reducing the window between compromise and detection.	High
MFA on All Privileged Accounts	Significantly raises the bar against credential-based attacks on administrative and database accounts.	Critical
Encryption of PII at Rest	Limits the value of raw database access to an attacker even if exfiltration occurs.	High
Formal Patch Management Process	Recurring vulnerabilities in the same platform indicate the absence of a structured remediation program.	High

2.2 Administrative and Training Controls

- **Secure Development Lifecycle:** Security gates must be built into the deployment process, with mandatory code review and vulnerability scanning before any customer-facing changes go live.
- **Data Minimization Policy:** When data collection is compelled by a DRM requirement, only the minimum necessary data should be collected, retained only as long as operationally required.
- **Developer Security Training:** All developers on customer-facing platforms must complete annual training on secure coding and OWASP Top 10. The recurring nature of Uplay's vulnerabilities suggests security was not embedded in the development culture.
- **Incident Response Tabletop Exercises:** The team clearly had no practiced response to a breach of this scale. Annual drills involving legal, communications, and executive stakeholders would have exposed those gaps before a real incident forced the issue.
- **Executive Security Briefings:** Security findings were not being escalated effectively to decision-makers. Leadership must receive regular updates on open vulnerabilities, remediation status, and platform risk posture.

3. Legal and Regulatory Compliance Considerations

Ubisoft is a French company headquartered in Paris with a global user base. The July 2013 breach affects multiple overlapping legal frameworks. An important caveat: 2013 predates GDPR, PIPEDA's breach notification regulations, and Quebec Law 25. The analysis below addresses what applied in 2013 and what would apply to an equivalent breach today — the latter being the more instructive frame for this course.

3.1 Applicable Legal and Regulatory Frameworks

Framework	Jurisdiction	Relevance
PIPEDA (+ SOR/2018-64 Breach Regulations)	Federal Canada	Applies to Ubisoft's commercial collection of Canadian user data. In 2013, no mandatory notification existed federally. Today, RROSH triggers OPC notification as soon as feasible.
Quebec Law 25 (Bill 64)	Quebec, Canada	Not in force in 2013; fully implemented September 2023. An equivalent breach today would require CAI notification within 72 hours and direct user notification where risk of serious injury exists.
EU Directive 95/46/EC (2013) / GDPR (post-2018)	European Union	Directive 95/46/EC applied in 2013, requiring adequate security but lacking uniform notification timelines. GDPR now requires 72-hour notification to the supervisory authority and user notification where high risk exists.
Loi Informatique et Libertés / CNIL	France	As a French company, Ubisoft was subject to French data protection law and CNIL oversight in 2013. The CNIL had authority to investigate and require remediation.
PCI-DSS	International	Ubisoft did not store payment card data directly, limiting exposure. However, the security of its environment and billing metadata it retained remained in scope.

3.2 Notification and Disclosure Obligations

In 2013, Ubisoft issued a public advisory to all Uplay users advising them to change their passwords, which satisfied the minimum expectation under the frameworks then in force. However, the notification omitted the number of users affected, the vulnerability exploited, and the password encryption method — all details that would be required under modern frameworks.

Under today's standards, the timeline would be tightly regulated. The CNIL and any relevant EU supervisory authority would require notification within 72 hours under GDPR Article 33. Canadian users would trigger OPC notification as soon as feasible under PIPEDA, and Quebec residents would trigger CAI notification within 72 hours under Law 25. Affected users across all jurisdictions would require direct notification where RROSH or high risk to rights and freedoms is established — which it clearly would be, given the scale and nature of the exposed data.

3.3 Repercussions and Infringements

In 2013, Ubisoft faced limited formal penalties due to the regulatory environment of the time. The reputational damage was more significant: three public security incidents in one year, compounding user frustration over mandatory DRM account creation, generated widespread negative coverage and genuine anger from the gaming community. Users who had no choice but to register on the platform felt, reasonably, that their trust had been abused.

Today, the financial exposure would be substantial. Under GDPR, fines can reach €20 million or 4% of annual global turnover, whichever is higher. With Ubisoft's revenues in the range of €1–2 billion, the theoretical GDPR ceiling exceeds €40 million. Quebec Law 25 adds potential penalties of up to \$25

million CAD or 4% of worldwide turnover. Beyond regulatory fines, a breach involving 58 million users in the current environment would almost certainly trigger class action litigation in both Canada and the EU. The mandatory nature of Uplay account creation — users had no meaningful choice about accepting the risk — would be a particularly difficult position to defend in court.

3.4 Alignment of SIR Form Responses with Legal and Compliance Issues

The SIR must not replicate Ubisoft's vague public language. The 'Affected Data' section must enumerate every category of data in the Uplay database at the time of the breach, including what was confirmed unaffected and the technical reason why (e.g., payment data held by third-party processors in a separate environment). The 'Root Cause' section must document the specific vulnerability, not just a reference to 'a website exploit.' The prior incidents must appear in the 'Contributing Factors' section — regulators would look at the pattern, not just the isolated event. And the actual notification timeline must be documented precisely, since that timeline is the starting point for assessing compliance with regulatory deadlines.

3.5 Missed or Ignored Compliance Controls — AAR Considerations

Missing Control	Relevant Standard	Impact
No holistic security review after prior incidents	NIST CSF ID.RA; ISO 27001 A.12.6	A pattern of vulnerabilities on the same platform went unaddressed, directly enabling the July breach.
Undisclosed (likely weak) password hashing	NIST SP 800-63B; OWASP Password Storage	Weak hashing significantly increases real-world harm from a stolen credential database.
No structured patch / vulnerability management program	PCI-DSS Req. 6; NIST SP 800-40	Recurring flaws in the same platform indicate no systematic process for identifying and remediating security issues.
Mandatory data collection without commensurate protection	PIPEDA Principle 4.4; GDPR Art. 5(1)(c)	Compelled account registration created a data protection obligation that the organization's security posture did not support.
No MFA on privileged accounts	PCI-DSS Req. 8.3; NIST SP 800-63B	Absence of MFA leaves credential-based access as the only barrier to privileged system access.
Insufficient breach notification transparency	PIPEDA SOR/2018-64; GDPR Art. 33/34; Law 25 s.3.7	Omitting key breach details from public and regulatory notifications would constitute non-compliance under current frameworks.
No continuous monitoring or anomaly detection	NIST CSF DE.CM; ISO 27001 A.12.4	Without active monitoring, the detection window cannot be managed or minimized.

As with any AAR, the value of identifying these gaps depends on whether they are acted on. Ubisoft had already experienced two prior incidents without making sufficient changes. The AAR following this breach needed ownership, deadlines, and a verification process — not just a list of recommendations.

4. Conclusion

The Ubisoft Uplay breach is defined by its context. A third major security incident on the same platform in a single year is not a question of bad luck or an unforeseeable zero-day. It reflects a failure to treat earlier incidents as preparation opportunities. The feedback loop that the NIST lifecycle depends on was not functioning.

The exposure of 58 million users' credentials was serious. The deeper problem was structural: a platform handling tens of millions of compelled registrations, with a documented vulnerability history, operating without the controls — a WAF, strong password hashing, MFA, active monitoring — that the situation plainly required. Legally, the 2013 regulatory environment limited formal consequences. That would not be true today, where GDPR, PIPEDA, and Quebec Law 25 together create a framework capable of imposing penalties well into the tens of millions.

The lesson is not complicated. Security incidents only reduce future risk if they drive genuine change in the preparation phase. Patching the immediate issue and moving on is not incident response — it is incident deferral.

Discord Data Breach

1. Linking Post-Incident Findings Back to the Preparation Phase

One of the fundamental ideas behind the NIST Incident Response Lifecycle is that post-incident activities shouldn't be isolated. The knowledge gained from even the most devastating security breaches should be used to enhance the organization's defenses otherwise it is bound to make the same errors again. From the perspective of the Discord.io breach, there are a number of SIR findings that the After-Action Review (AAR) must address without fail. Some of these, when reflected upon, appear quite evident, but that's usually the case with security incidents.

1.1 The Root Cause: A Vulnerability in the Website's Own Code

Perhaps the single most critical issue the AAR requires to focus on is the means by which the attacker managed to get initial access without any resistance. The perpetrator, who in the cyber arena also goes by the name 'Akhirah,' entered the system by taking advantage of a defect in Discord.io's webpage programming, which is not a rare or complex type of attack at all. Vulnerabilities of a website or web application are among the most widely documented kinds of security risks, and have been even extensively covered by the OWASP Top 10, for instance. Therefore, the very fact that a vulnerable piece of code was present in the production version prompts a fundamental question: were there any steps in place such as code review, security testing, or vulnerability scanning prior to deployment? In view of the available data, it is likely the answer is no. The AAR needs to find out if Discord.io ever had a Secure Software Development Lifecycle (SSDLC), and if not, then that alone would be the most urgent corrective action item. Moreover, a Web Application Firewall (WAF) might have even detected or at least hindered the exploitation process of the vulnerable code, had the latter been present in the production; however, this also seems not to have been the case.

1.2 The Entire Database Was Accessible

During the exploitation of this weakness, Akhirah presumably managed to download the whole user database. This point is very important. If the environment is segmented properly, as per the principle of least privilege, a web application vulnerability should not give an attacker the ability to read every record in the database without any restriction. The AAR must find out how database permissions were set up, if the web application's service account had much more access than it actually required, and whether there was any monitoring of database activity aimed at detecting large data exports. Simply put, judging by what has happened, the access controls were way too permissive.

1.3 Passwords from 2018 and Earlier Were Still in the Database

This is one instance that really deserves a moment of reflection. Discord.io switched their login system to OAuth-only in 2018, which effectively prohibited users from setting a traditional password from that point onwards. However, the salted and hashed passwords of users who had registered before that switch appeared to be still left in the database years after that. There was no retrospective cleaning, no re-encryption, and no data minimization policy that would have considered this data as unnecessary to keep. In fact, from any reasonable perspective of

the principle of data minimization which is recognized in PIPEDA, Quebec Law 25, and GDPR, that data definitely should not have been there anymore. The AAR has to set up a proper data retention and deletion timeline in the future.

1.4 The Breach Was Discovered on a Hacker Forum, Not Internally

Perhaps the most telling indicator of the organization's security posture is how the breach was actually detected. Discord.io did not find out about the incident through its own monitoring tools, intrusion detection systems, or anomaly alerts. They found out because a threat actor posted their database for sale on BreachForums. That is an external, reactive discovery, and it's about as late as detection can possibly get. By the time an organization discovers a breach this way, the data has already been harvested, exfiltrated, and offered to buyers. The AAR must prioritize building proactive detection capabilities, including dark web monitoring, database access logging, and network-level anomaly detection.

1.5 Third-Party Risk Was Not Adequately Managed

Discord.io operated as a third-party service built on top of Discord's OAuth infrastructure. Discord itself was not breached, and they were quick to clarify publicly that they had no affiliation with or control over Discord.io's data handling. However, this incident highlights a broader concern about third-party risk management. Users who connected their Discord accounts to Discord.io likely had no meaningful awareness of how their data was being stored or protected. Discord, for its part, did revoke OAuth tokens for affected users after the breach was confirmed, which was a reasonable response, but it was reactive. The AAR should explore what a more proactive third-party vetting process would look like, both for Discord.io itself and for organizations that rely on third-party OAuth integrations.

2. Recommended Controls and Training

Based on the findings above, the following controls and training measures should be introduced or significantly improved. These are not theoretical recommendations — each one maps directly to a gap that either caused or worsened the breach.

2.1 Technical Controls

Control	What It Addresses	Priority
Web Application Firewall (WAF)	Detects and blocks exploitation of web vulnerabilities, including SQL injection and other OWASP Top 10 attacks, even when vulnerable code reaches production.	Critical
Regular Penetration Testing and Code Audits	Would have identified the exploited vulnerability before it was discovered by a threat actor. Should be conducted by independent third parties at least annually.	Critical
Database Activity Monitoring (DAM)	Flags and alerts on unusual queries or bulk data exports, which could have detected the attacker's activity in real time during the exfiltration.	High
Principle of Least Privilege on Database Access	Restricts web application service accounts to only the specific tables and operations they need, limiting the blast radius of any future exploit.	High
MFA on All Administrative and Database Accounts	Prevents unauthorized access even if credentials are compromised. Should be mandatory, not optional, for anyone with elevated access.	Critical
Encryption of Personal Data at Rest	Ensures that even if a database is exfiltrated, the contents are unreadable without the encryption keys. Particularly important for email addresses and billing data.	High
Dark Web and Threat Intelligence Monitoring	Provides early warning if organizational data or credentials appear on criminal forums, shifting discovery from reactive to proactive.	Medium
IDS/IPS Deployment	Detects anomalous network traffic patterns associated with data exfiltration or lateral movement.	High

2.2 Administrative Controls

From a process perspective, the biggest issue was that there was not a single formal Incident Response Plan with procedural notifications defined. This means that had a plan been in place, the company would have exactly understood whom to call, what schedules to observe, and how to talk to side users. As a matter of fact, the reply, though quite swift in some ways, looked in large measure to have been made up on the spur of the moment. Besides an IRP, the company required a formal data retention policy, which would have led to the disposal of the pre-2018

password data long before the breach even took place. A Secure Software Development Lifecycle with security gates integrated into the deployment process would have remedied the root cause vulnerability. And a Third-Party Risk Management framework would have motivated both Discord. io and its parent ecosystem to ponder more seriously security commitments when dealing with other people's data. Besides, a Vulnerability Disclosure Policy is definitely something that could be introduced not as a reactive step but rather as a continuous offer for the ethical researchers to report issues before the criminals discover them first.

2.3 Training Recommendations

- **Developer Security Training:** For all the developers working on Discord. io's codebase, it is a must to do a formal secure coding training. The training should heavily focus on OWASP Top 10 and input validation. The fact that a web application vulnerability was unnoticed and unpatched for a long time to the point of being exploited only shows that security was not made a part of the development culture.
- **Annual Security Awareness Training:** Every employee has to be security awareness trained on topics like phishing, social engineering, data classification, and breach notification. This is a minimum requirement in most privacy frameworks and should not be considered as optional.
- **Tabletop Exercises and IR Drills:** The company definitely did not have a rehearsed breach response situation. Frequent tabletop exercises would have made them realize the flaws in their IRP or that they didn't have one at all even before a real incident came and forced the point.

3. Legal and Regulatory Compliance Considerations

Discord.io operated as a global third-party service, but given that its user base included Canadian residents, the breach triggers meaningful obligations under Canadian federal and provincial privacy law. The analysis below addresses the five subsections required under the assignment rubric. Where applicable, international frameworks are also noted, as a breach of this scale does not exist in a single legal jurisdiction.

3.1 Applicable Legal and Regulatory Frameworks

Several overlapping legal frameworks apply to this incident, depending on the nationality of affected users and the nature of data involved.

Framework	Jurisdiction	Why It Applies
PIPEDA — Personal Information Protection and Electronic Documents Act	Federal (Canada)	Discord.io collected email addresses, billing addresses, and payment information from users in the course of operating a commercial service. This squarely falls within PIPEDA's scope. The breach of security safeguards regulations under PIPEDA (SOR/2018-64) came into force in November 2018 and impose specific notification and record-keeping obligations.
Quebec Law 25 (Bill 64) — Act Respecting the Protection of Personal Information in the Private Sector	Province of Quebec (Canada)	Law 25 completed its phased implementation in September 2023, just weeks after this breach. It introduced GDPR-style requirements including mandatory 72-hour breach notification to the Commission d'accès à l'information (CAI), privacy impact assessments, and stricter consent requirements for data collection. Any Quebec residents affected by this breach fall under Law 25.
CASL — Canada's Anti-Spam Legislation	Federal (Canada)	Not triggered directly by the breach itself, but relevant if harvested email addresses are subsequently used for spam or phishing campaigns targeting Canadian users. Discord.io has an obligation to monitor for and report such misuse.
PCI-DSS — Payment Card Industry Data Security Standard	International Standard	Discord.io accepted payments for premium subscriptions via Stripe and PayPal. While those processors handled cardholder data directly, Discord.io was still responsible for the security of its own environment and any payment metadata it retained, such as billing addresses and payment dates.
GDPR — General Data Protection Regulation	European Union	If EU residents were among the 760,000 affected users — which is almost certain given the global nature of the Discord platform — GDPR applies. This includes the 72-hour notification requirement under Article 33 and the obligation to notify affected data subjects under Article 34 where there is a high risk to their rights and freedoms.

3.2 Notification and Disclosure Obligations

This message is tricky because more than one regulator could be involved, and each one has different deadlines and requirements for reporting. According to PIPEDA's regulations on reporting security breaches, an organization must notify the Office of the Privacy Commissioner of Canada (OPC) immediately if there is a real risk of significant harm to the affected individuals. Significant harm includes identity theft, loss of job, and financial loss, which are very likely to happen when email addresses, billing addresses, Discord IDs, and hashed passwords are offered for sale on a dark web forum. Therefore, this situation definitely represents an RROSH. The company must notify the persons involved directly besides making a report to the Office of the Privacy Commissioner of Canada (OPC), and they must keep the record of the breach for 24 months at least.

Under Quebec Law 25, the deadline for reporting a data breach to the CAI is significantly shortened. In fact, organizations are required to notify the CAI within 72 hours of being aware of a breach of confidentiality that could lead to serious harm. As Discord.io acknowledged the breach on August 14 2023 after finding the BreachForums post, the 72-hour countdown began on that day. It is not known from public sources if the deadline was really met and that uncertainty alone might put the company under the regulators' scope. The same 72-hour window is also provided by GDPR for reporting to the competent supervisory authority in the EU, and notification of the data subjects affected by the breach is a requirement when there is high risk to their rights and freedoms. The fact that a data set with email addresses, Discord IDs, and billing information has been compromised is, in all likelihood, already enough for a high-risk situation.

Regulator / Party	Notification Trigger	Timeline
Office of the Privacy Commissioner (OPC) — Canada	Real Risk of Significant Harm established	As soon as feasible
Commission d'accès à l'information (CAI) — Quebec	Risk of serious injury to Quebec residents	Within 72 hours of awareness
EU Data Protection Authority (DPA)	Breach involving personal data of EU residents	Within 72 hours of awareness
Affected Individuals (all jurisdictions)	RROSH or equivalent threshold met	As soon as feasible; concurrent with regulator notification
Stripe and PayPal (payment processors)	Potential compromise of payment environment or metadata	Per contractual obligations; immediately upon confirmation

3.3 Repercussions and Infringements

The legal and financial consequences of this breach are not trivial, even accounting for Discord.io's relatively small size as an organization.

Under PIPEDA as currently written, there are no direct financial penalties for organizations that fail to comply with breach notification requirements — a widely acknowledged weakness in the Canadian privacy landscape. However, the OPC can conduct investigations, publish findings publicly, and refer serious cases to Federal Court. Public naming is itself a significant reputational consequence, particularly for a platform that depends on user trust. It is also worth

noting that Bill C-27, the proposed successor to PIPEDA, would introduce administrative monetary penalties of up to \$10 million CAD or 3% of global gross revenue. While it had not yet passed into law at the time of the breach, its trajectory signals a tightening regulatory environment.

Quebec Law 25 is considerably more aggressive on enforcement. The CAI has the authority to impose administrative monetary penalties of up to \$25 million CAD or 4% of worldwide turnover for serious violations, including failure to notify within the required 72-hour window and failure to implement adequate security safeguards. These numbers are not hypothetical — the CAI has signaled its intent to actively enforce Law 25 since its full implementation in September 2023.

For EU-resident users, the applicable supervisory authority could impose GDPR fines under Article 83 of up to €20 million or 4% of annual global turnover, whichever is greater. On top of regulatory fines, affected users in multiple jurisdictions may have standing to pursue civil litigation for damages stemming from identity theft, phishing, or the misuse of their exposed contact information. Class action suits in data breach cases have become increasingly common in both Canada and Europe.

The most immediate consequence, however, was simply that Discord.io ceased to exist as a functioning service. The organization shut down all operations in the wake of the breach, canceled premium subscriptions, and never meaningfully relaunched. In practical terms, the reputational damage was fatal to the business. That outcome — while not a ‘penalty’ in the legal sense — is the clearest possible illustration of what inadequate security controls can cost.

3.4 Alignment of SIR Form Responses with Legal and Compliance Issues

For the SIR to be legally useful — whether for regulatory submissions, litigation, or internal accountability — its contents need to be precise, consistent, and compliance-conscious. Several specific alignment points are worth flagging.

First, the ‘Affected Data’ section of the SIR must enumerate every category of exposed information with specificity: email addresses, Discord IDs, internal user IDs, billing addresses, payment dates, salted and hashed passwords for pre-2018 accounts, and API keys. The reason precision matters here is that the RROSH determination under PIPEDA and the ‘risk of serious injury’ assessment under Law 25 both depend on the nature of the data involved. A vague description of ‘user account information’ does not support a rigorous legal analysis and could be read as an attempt to downplay the severity of the incident.

Second, the discovery timeline in the SIR must be accurate down to the date and, ideally, the time. Discord.io became aware of the breach on August 14, 2023, when the BreachForums listing was discovered. That date is the starting point for the 72-hour notification clocks under Law 25 and GDPR. Any inconsistency between the SIR and the notification records submitted to regulators could itself become evidence of non-compliance.

Third, the containment actions documented in the SIR — shutting down all services, revoking OAuth tokens in coordination with Discord, canceling premium subscriptions — are important not just as operational records but as evidence of good-faith mitigation. Regulators typically consider the speed and appropriateness of an organization’s response when determining penalties. A well-documented containment section works in the organization’s favour.

Finally, the SIR should clearly delineate what data Discord.io held directly versus what was held by Stripe and PayPal. Payment card numbers and CVVs were handled by the processors, not by Discord.io. Drawing that distinction clearly in the SIR limits the organization’s PCI-DSS

exposure and prevents regulators from drawing incorrect conclusions about the scope of the breach.

3.5 Missed or Ignored Compliance Controls — AAR Considerations

Looking back at the breach, there is a fairly clear pattern: the controls that were missing are not obscure or cutting-edge — they are foundational. Most of them are explicitly required by PIPEDA, Law 25, or PCI-DSS. Their absence was not just a technical gap; it was a compliance failure.

Missing Control	Relevant Standard	How It Contributed to the Breach
No encryption of personal data at rest (email addresses, billing addresses)	PIPEDA Principle 7 (Safeguards); Law 25 s.3.6	Once the database was exfiltrated, all personal information was immediately readable. Encryption at rest would not have prevented the breach but would have significantly reduced the harm to individuals.
Pre-2018 hashed passwords retained without purge or re-encryption	PIPEDA Principle 5 (Limiting Retention); Law 25 s.3.5 (data minimization)	Data that served no current operational purpose was still in the database years after the credential format was deprecated. A basic retention policy would have eliminated this exposure.
No WAF or runtime vulnerability detection	PCI-DSS Requirement 6.6; OWASP Application Security Best Practices	The code vulnerability used by the attacker went undetected in production. A WAF could have identified and blocked the exploitation attempt even without a code fix.
No dark web or threat intelligence monitoring	NIST CSF — Detect Function (DE.CM-1, DE.CM-7)	Discovery came from an external source (BreachForums), not from internal monitoring. Earlier detection would have reduced the window during which data was available for purchase.
No documented Incident Response Plan with notification procedures	PIPEDA Breach Regulations (SOR/2018-64); Law 25 s.3.7; NIST SP 800-61	Without a plan, the 72-hour notification clocks under Law 25 and GDPR became a compliance risk in themselves. There is no evidence that regulatory notifications were made within the required windows.
No MFA on administrative and database accounts	PCI-DSS Requirement 8.3; NIST SP 800-63B	If the attacker had obtained admin credentials through any means, MFA would have been the last line of defence. Its absence represents a fundamental gap in access control.
Overly permissive database access for the web application	PIPEDA Principle 7; PCI-DSS Requirement 7 (Least Privilege)	The application account apparently had read access to the entire database. Properly scoped permissions would have limited the scope of what could be exfiltrated through a single vulnerability.

Each item in the table above needs to appear as a formal corrective action in the AAR, with an assigned owner, a target completion date, and a verification step. That is not bureaucratic box-ticking — it is how organizations demonstrate to regulators, insurers, and their own leadership that lessons were actually learned. An organization that suffers a breach, identifies the contributing gaps, and then fails to remediate them faces a significantly harsher regulatory response if a second incident occurs.

4. Conclusion

The Discord.io breach is, in many ways, a straightforward case. A third-party service handling the personal data of 760,000 people had no meaningful security controls protecting that data. A single web application vulnerability gave an attacker complete access to the database. The breach was discovered not by the organization itself but by a threat actor posting the data for sale on a criminal forum. The service subsequently shut down entirely.

What makes this case instructive is not its technical complexity — it has none — but rather how cleanly it illustrates the consequences of treating security as an afterthought. Every gap identified in this analysis corresponds to a well-established control that has existed for years and is explicitly referenced in the frameworks Discord.io was almost certainly obligated to follow. PIPEDA, Quebec Law 25, and PCI-DSS did not require anything exotic. They required encryption, access controls, breach notification procedures, and retention policies. None of those were in place.

From an incident response perspective, the post-incident findings documented in this analysis only have value if they are taken seriously in the preparation phase. The NIST lifecycle is circular by design: preparation should be informed by past incidents, including this one. The AAR needs to produce actionable, time-bound corrective measures — not a list of things to ‘consider.’ And critically, those measures need to be verified, not just documented. A control that exists on paper but has never been tested is not meaningfully different from no control at all.

The Discord.io case ended badly for the organization. But for incident response practitioners, it offers a clear and well-documented example of what happens when the basics are skipped.